SECURITY

CSRF & SSRF Visual Guide

Cross-Site Request Forgery & Server-Side Request Forgery — when requests lie about their origin.

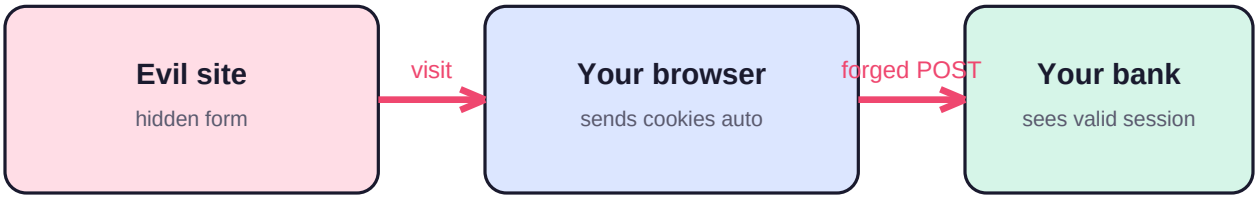
ANIMATED WALKTHROUGH

Step through pages to play the animation

STEP 1/6

CSRF Mechanics

Your browser, the attacker's request.



Cookies go along automatically — the server can't tell your click from the attacker's. State-changing requests need proof of intent.

STEP 2/6

CSRF Defenses

Tokens + SameSite cookies end it.

CSRF tokens

Unpredictable per-session token in every form/API call; server rejects mismatc

SameSite cookies

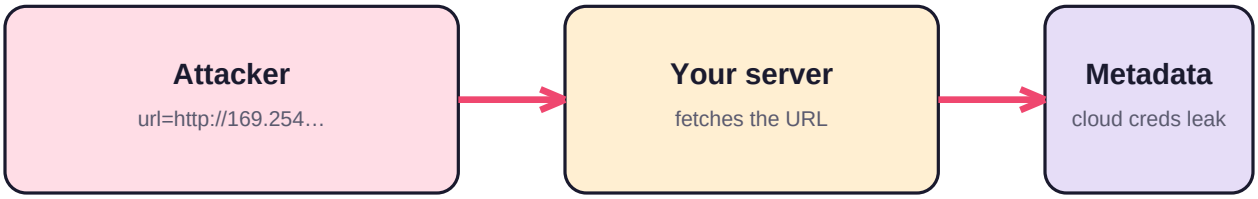
Lax/Strict: browser won't send cookies on cross-site requests.

SameSite is the seatbelt, tokens are the airbag — deploy both. GET requests must never change state.

STEP 3/6

SSRF Mechanics

Trick YOUR server into attacking your network.



Cloud metadata endpoints (169.254.169.254) hand out credentials to anything that asks — including your tricked server.

STEP 4/6

SSRF Defenses

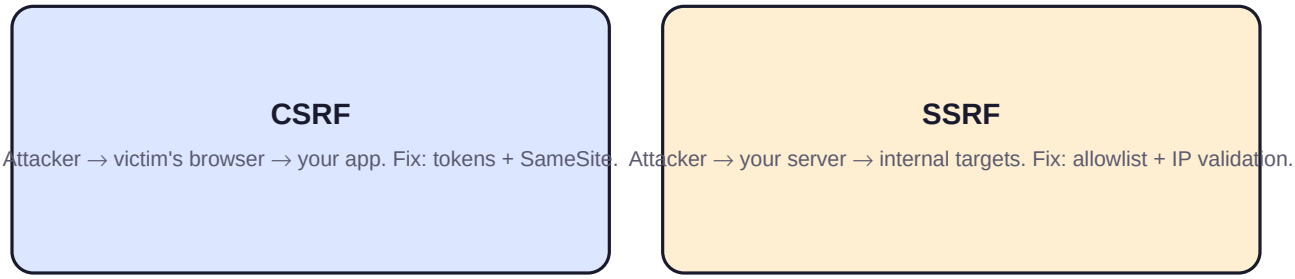
Never let user input choose server destinations freely.

- Allowlist egress: only fetch from approved hosts/schemes; deny by default.
- Block private ranges: 10/8, 172.16/12, 192.168/16, 169.254/16, localhost.
- Resolve-then-validate: DNS-rebinding defeats naive hostname checks — validate the IP too.
- Disable metadata endpoint access (IMDSv2 with hop limits) as a backstop.

STEP 5/6

CSRF vs SSRF at a Glance

Mirror images: one abuses the browser, one abuses the server.



STEP 6/6

Request-Forgery Checklist

Cover both sides of the mirror.

- Every state-changing endpoint requires a CSRF token; cookies are SameSite=Lax+.
- Server-side fetches use an allowlisted egress proxy — no raw user URLs.
- Private IP ranges blocked at the fetch layer AND the firewall.
- Test both with dedicated payloads in every pentest and DAST run.

STEP ✓I✓

Key Takeaways

CSRF & SSRF — Remember

- CSRF rides your browser's automatic cookies — prove intent with tokens.
- SameSite cookies + CSRF tokens together; GETs never change state.
- SSRF tricks your server into fetching internal targets like metadata endpoints.
- Allowlist egress destinations; block private IP ranges; validate resolved IPs.
- Harden cloud metadata (IMDSv2) as a backstop against credential theft.
- Test both forgery types in every security assessment.

Keep exploring

Pair this guide with the matching video walkthroughs
and hands-on labs at interstitiumlabs.dev